

Cybersecurity Lab Report

Web Technology Fingerprinting with WhatWeb & Nikto

Target: Metasploitable2 (192.168.255.128) • Attacker: Kali Linux • Date: June 2, 2026

1. Introduction

This report documents the use of WhatWeb and Nikto for web application reconnaissance against the Metasploitable2 target. WhatWeb is a web technology fingerprinting tool that identifies CMS platforms, server software, scripting languages, framework versions, cookies, email addresses, and security headers by analyzing HTTP responses. Nikto is a web server scanner that checks for dangerous files, outdated software versions, and missing security headers.

Beyond the lab target, WhatWeb is also demonstrated against real-world websites (guatemala.gob.gt and click.gt) to illustrate how the tool operates against Cloudflare-protected and Shopify-hosted production sites, and Wappalyzer (a browser extension) is shown as a complementary technology detection tool.

2. WhatWeb — Scanning the Metasploitable2 Web Services

2.1 — Individual Port Scans (Ports 8080–8085)

WhatWeb was run individually against each of the six web services exposed by the Metasploitable2 container. Each scan revealed the server technology, PHP version, CMS, redirects, cookies, and page titles.

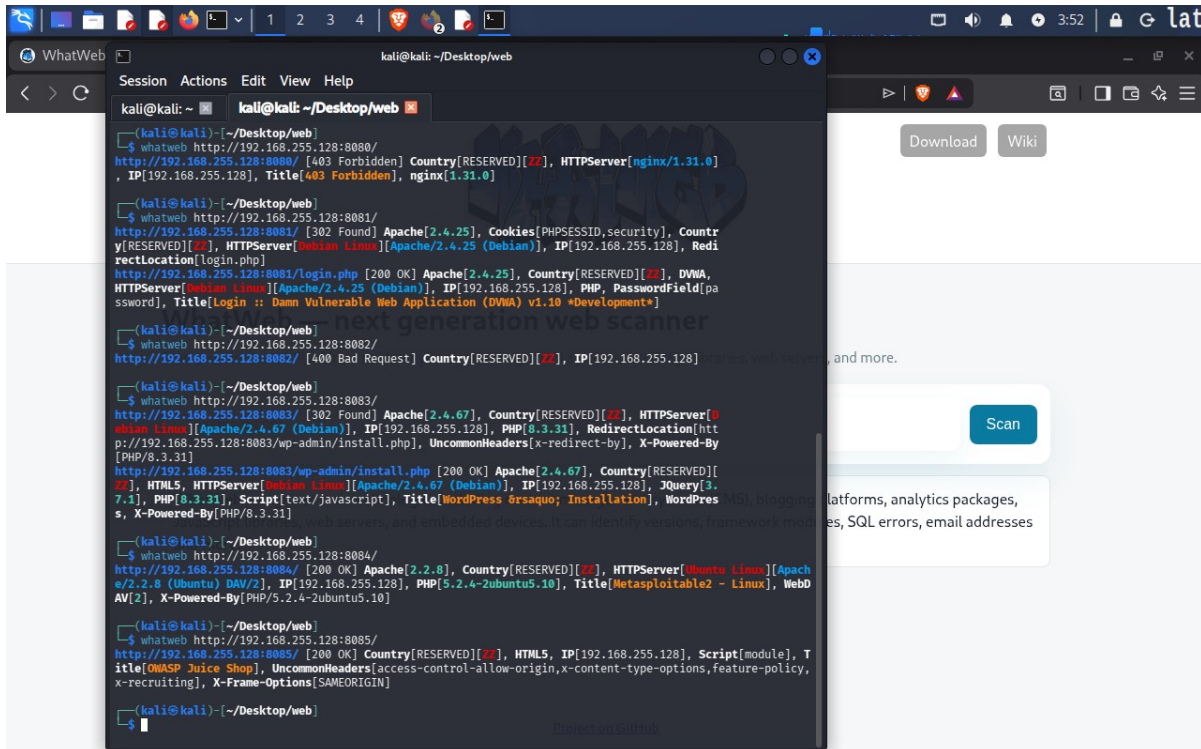


Figure 1 — Kali terminal: six sequential WhatWeb scans against the Metasploitable2 target ports. Port 8080: [403 Forbidden] HTTPServer[nginx/1.31.0], Title[403 Forbidden]. Port 8081: [302 Found] Apache[2.4.25], Cookies[PHPSESSID,security], Debian Linux, redirect to login.php; login.php [200 OK] DVWA, PasswordField[password], Title[Login :: Damn Vulnerable Web Application (DVWA) v1.10]. Port 8082: [400 Bad Request] Country[RESERVED]. Port 8083: [302 Found] Apache[2.4.67], Debian Linux, PHP[8.3.31], redirect to wp-admin/install.php; install.php [200 OK] HTML5, JQuery[3.7.1], Title[WordPress Installation]. Port 8084: [200 OK] Apache[2.2.8], Ubuntu Linux, PHP[5.2.4-2ubuntu5.10], Title[Metasploitable2 — Linux], WebDAV[2]. Port 8085: [200 OK] HTML5, Title[OWASP Juice Shop], UncommonHeaders[access-control-allow-origin, x-content-type-options, feature-policy, x-recruiting], X-Frame-Options[SAMEORIGIN].

2.2 — Batch Scan from sites.txt File

To scan all ports at once, a sites.txt file was created with all six target URLs. WhatWeb was first tested against its own website (whatweb.net), then `cat sites.txt` confirmed the file contents, and `whatweb -i sites.txt` was run to scan all targets in batch. An initial parse error on the "Web URLs>" header line was reported but WhatWeb proceeded and scanned all six URLs, producing a condensed one-line-per-URL output.

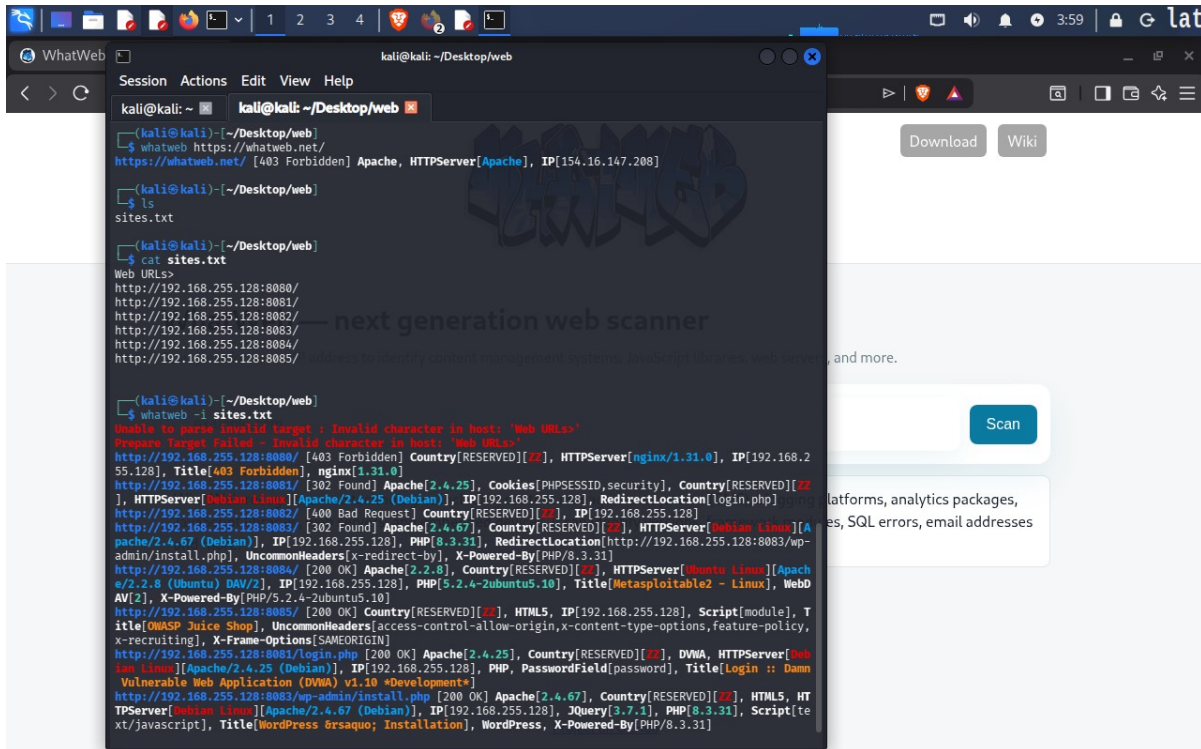


Figure 2 — Kali terminal: `whatweb https://whatweb.net/` returns `[403 Forbidden] Apache, HTTPServer[Apache], IP[154.16.147.208]`. Then `ls` shows `sites.txt`; `cat sites.txt` displays the file contents: "Web URLs>" header followed by six target URLs (192.168.255.128:8080 through :8085). `whatweb -i sites.txt` run: error parsing "Web URLs>" line (invalid character in host), then all 6 URLs scanned successfully. Output shows: 8080 `[403 Forbidden] nginx[1.31.0]`; 8081 `[302 Found] Apache[2.4.25], PHPSESSID, Debian Linux`; 8082 `[400 Bad Request]`; 8083 `[302 Found] Apache[2.4.67], PHP[8.3.31], redirect to wp-admin/install.php, X-Powered-By[PHP/8.3.31]`; 8084 `[200 OK] Apache[2.2.8], Ubuntu Linux, Metasploitable2, WebDAV[2]`; 8085 `[200 OK] OWASP Juice Shop, SAMEORIGIN`; 8081/login.php `[200 OK] DVWA login`; 8083/wp-admin/install.php `[200 OK] WordPress Installation`.

3. WhatWeb — Real-World Site Testing

3.1 — Guatemala Government Site: Verbose Scan (-v)

WhatWeb was run against `guatemala.gob.gt` with the verbose flag (`whatweb https://guatemala.gob.gt/ -v`) to demonstrate plugin-level output. The site returned 403 Forbidden, indicating Cloudflare protection. WhatWeb identified: HTML5, HTTPServer[cloudflare], Script, and multiple UncommonHeaders including CSP, critical-ch, cross-origin policies, permissions-policy, referrer-policy, server-timing, x-content-type-options, report-to, NEL, and CF-RAY. X-Frame-Options[SAMEORIGIN] and X-UA-Compatible[IE=Edge] were also detected.

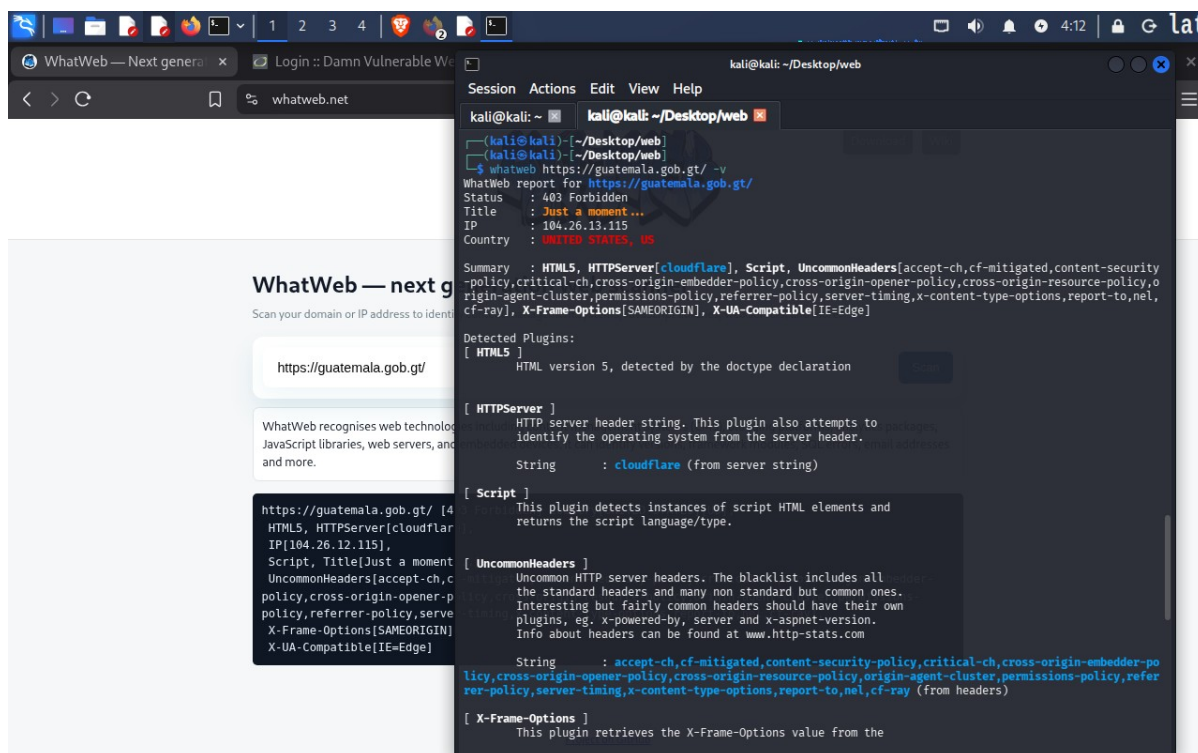


Figure 3 — Kali terminal + WhatWeb homepage (browser): `whatweb https://guatemala.gob.gt/ -v`. Verbose output: Status: 403 Forbidden, Title: "Just a moment...", IP: 104.26.12.115, Country: UNITED STATES, US. Summary: HTML5, HTTPServer[cloudflare], Script, UncommonHeaders[accept-ch, cf-mitigated, content-security-policy, critical-ch, cross-origin-embedder-policy, cross-origin-opener-policy, cross-origin-resource-policy, origin-agent-cluster, permissions-policy, referrer-policy, server-timing, x-content-type-options, report-to, nel, cf-ray], X-Frame-Options[SAMEORIGIN], X-UA-Compatible[IE=Edge]. Detected Plugins expanded: [HTML5] HTML version 5; [HTTPServer] cloudflare from server string; [Script]; [UncommonHeaders] full header blacklist content shown; [X-Frame-Options].

3.2 — Full Cloudflare Response Headers

The verbose output continued to display the complete raw Cloudflare response headers, including the full Content-Security-Policy (referencing challenges.cloudflare.com), Accept-CH headers listing all client hints (Sec-CH-UA-Bitness, Sec-CH-UA-Arch, Sec-CH-UA-Full-Version, etc.), Cross-Origin policies, Permissions-Policy with all browser feature controls, Referrer-Policy, Server-Timing, X-Content-Type-Options, X-Frame-Options, CF-RAY identifier, and NEL (Network Error Logging) configuration.

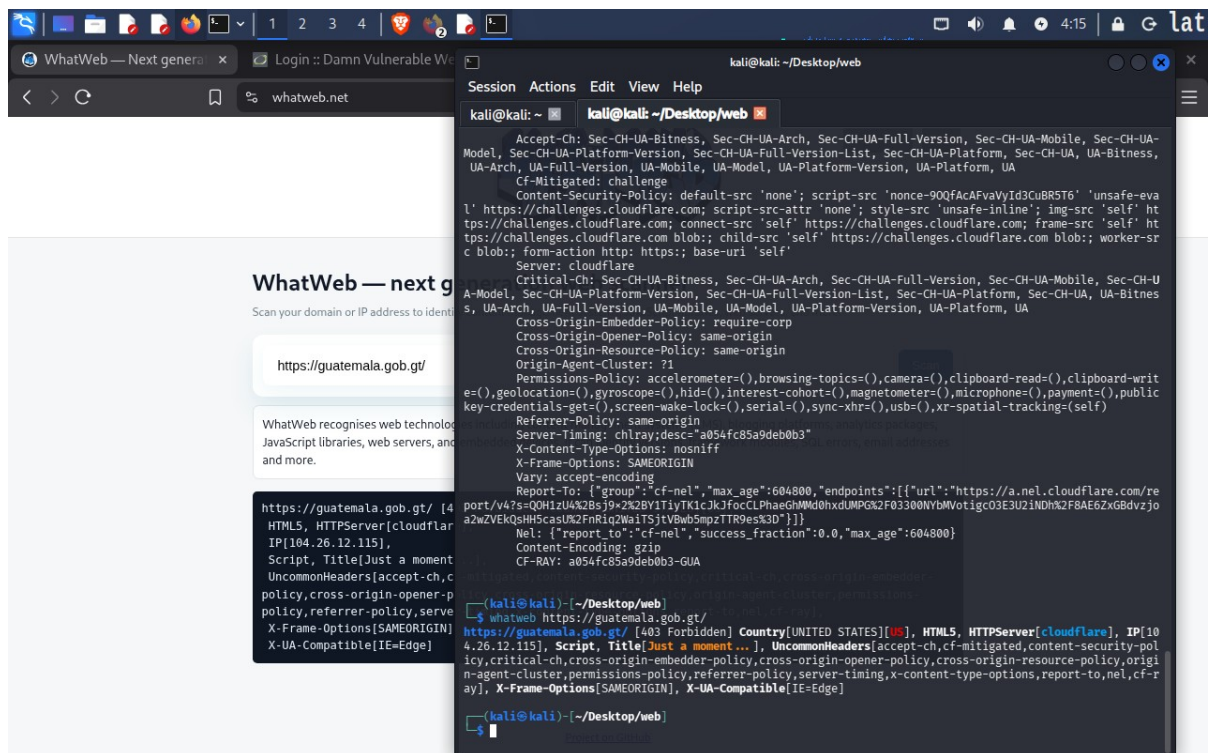


Figure 4 — Kali terminal: continuation of verbose WhatWeb output for guatemala.gob.gt — raw HTTP response headers fully expanded. Accept-CH headers list all client hint categories. CF-Mitigated: challenge. Content-Security-Policy: script-src nonce with Cloudflare challenges URLs. Critical-CH and multiple Sec-CH-UA headers. Cross-Origin-Embedder-Policy: require-corp. Cross-Origin-Opener-Policy: same-origin. Cross-Origin-Resource-Policy: same-origin. Origin-Agent-Cluster: ?1. Full Permissions-Policy list (accelerometer, browsing-topics, camera, clipboard, geolocation, gyroscope, etc.). Referrer-Policy: same-origin. Server-Timing: chlrly. X-Content-Type-Options: nosniff. X-Frame-Options: SAMEORIGIN. CF-RAY: a054fc85a9deb0b3-GUA. NEL and Report-To JSON configs. Then: `whatweb https://guatemala.gob.gt/` (non-verbose) returns single-line summary. Then: `whatweb -U "Mozilla/5.0 (Linux; Android 14; TB360ZU Build/UKQ1.231108.001; wv) AppleWebKit/537.36..." https://guatemala.gob.gt/` returns same 403 Forbidden result with Cloudflare headers unchanged.

3.3 — User-Agent Switching: Active User-Agent Browser Extension

To demonstrate how WhatWeb (and browsers) can spoof User-Agent strings to attempt to bypass Cloudflare bot detection, the Active User-Agent Firefox extension was shown with the guatemala.gob.gt site loaded. The extension was set to an Android mobile User-Agent (Mozilla/5.0 Linux; Android 11.2 KHTML, Chrome/132.0 Mobile Safari/537.36), enabled on the domain.



Figure 5 — Firefox displaying guatemala.gob.gt (Government of Guatemala website) with the Active User-Agent browser extension popup open. Extension shows the active User-Agent string: "Mozilla/5.0 (Linux; Android 11.2; MRX-AL09) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/132.0.7051.94 Mobile Safari/537.36". Toggle options for browser (Chrome, Firefox, Safari, Edge, Opera) and OS (Linux, Windows, macOS, Android) shown. "Enabled on this domain" toggle is ON. The website displays a "DANDO ALIVIO AL COSTO DE VIDA / GUATEMALA SALE AD..." campaign banner.

3.4 — iOS User-Agent on Facebook

The Active User-Agent extension was also used on m.facebook.com with an iOS Safari User-Agent to demonstrate mobile browser impersonation. This shows how fingerprinting tools and attackers alike can manipulate headers to probe for platform-specific content or vulnerabilities.

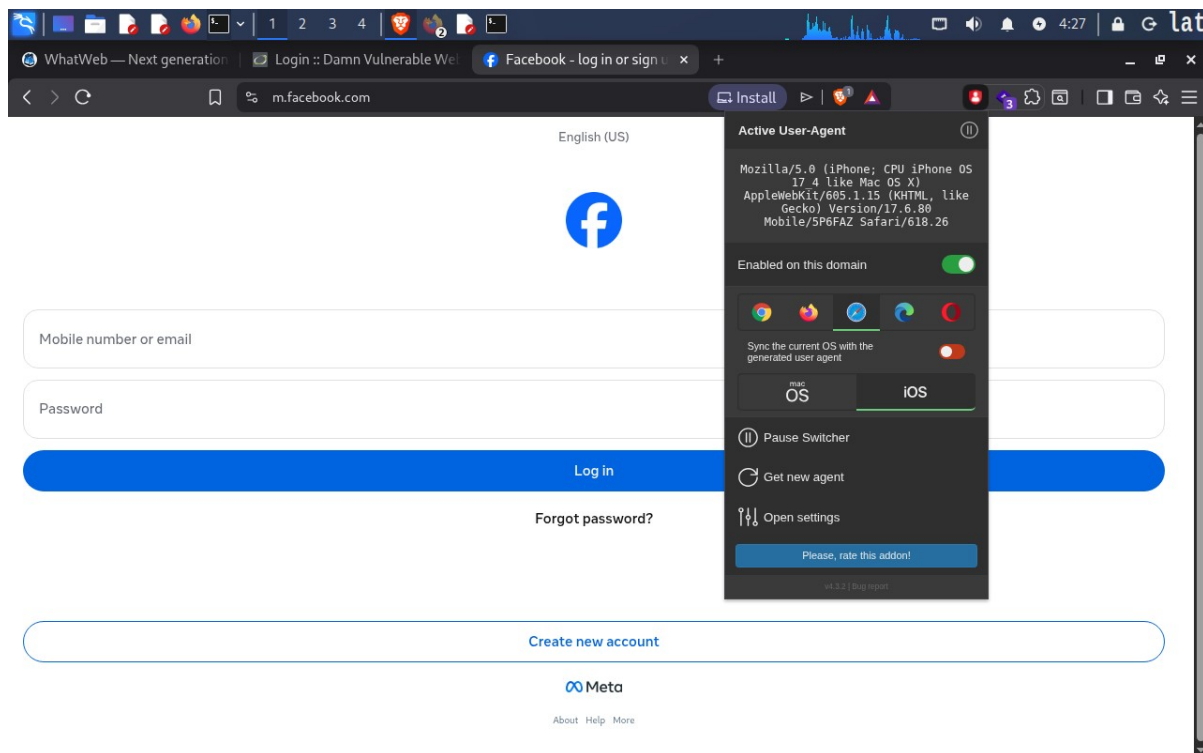


Figure 6 — Firefox displaying m.facebook.com (Facebook mobile login page) with Active User-Agent extension popup. Active User-Agent: "Mozilla/5.0 (iPhone; CPU iPhone OS 17.4 like Mac OS X) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/17.6.80 Mobile/5P6FAZ Safari/618.26". iOS tab selected (highlighted). "Enabled on this domain" ON. Facebook mobile login form visible with email/password fields, Log in button, Forgot password link, Create new account, Meta branding.

3.5 — Wappalyzer on Guatemala Government Site

The Wappalyzer browser extension was used to visually confirm the technology stack of guatemala.gob.gt, providing a complementary view to WhatWeb's command-line output. Wappalyzer identified: CMS WordPress, CDN Cloudflare, Widgets Slider Revolution 6.5.16, Photo Galleries Slider Revolution 6.5.16, Page Builder wpBakery and Elementor 3.12.1, Analytics Site Kit 1.158.0 and Google Analytics GA4, SEO All in One SEO Pack 4.6.1.1, Databases MySQL.

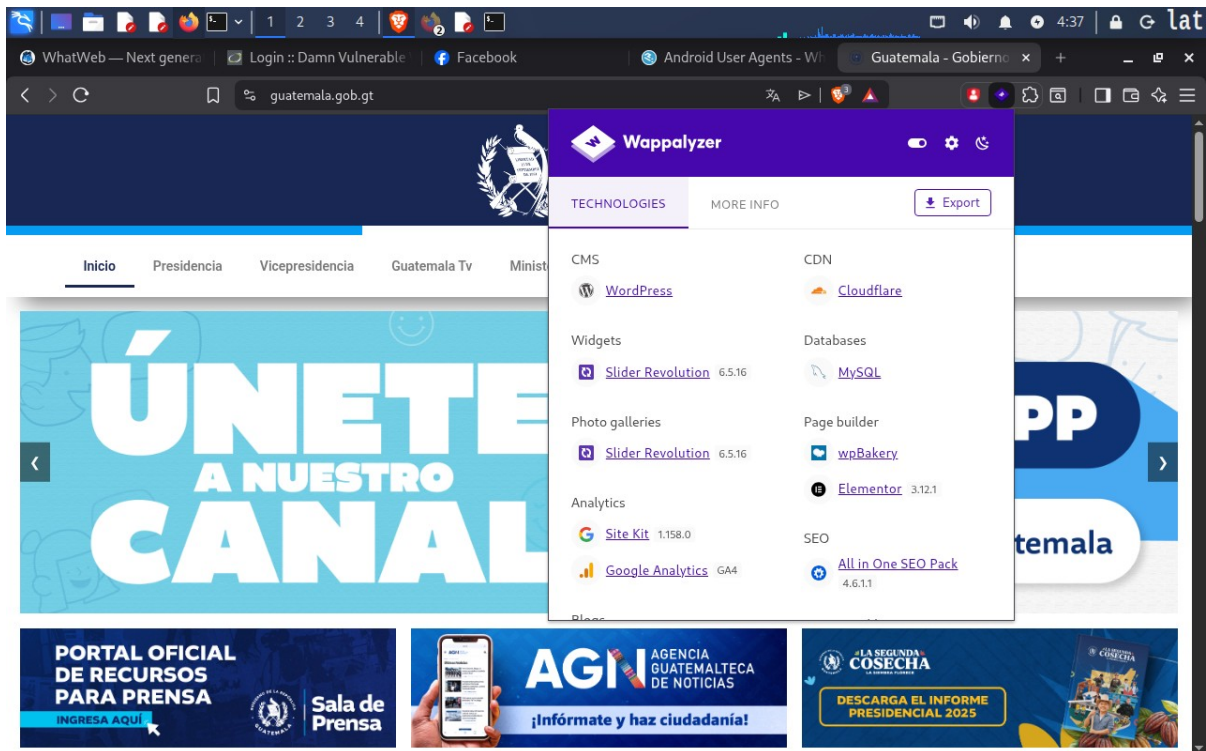
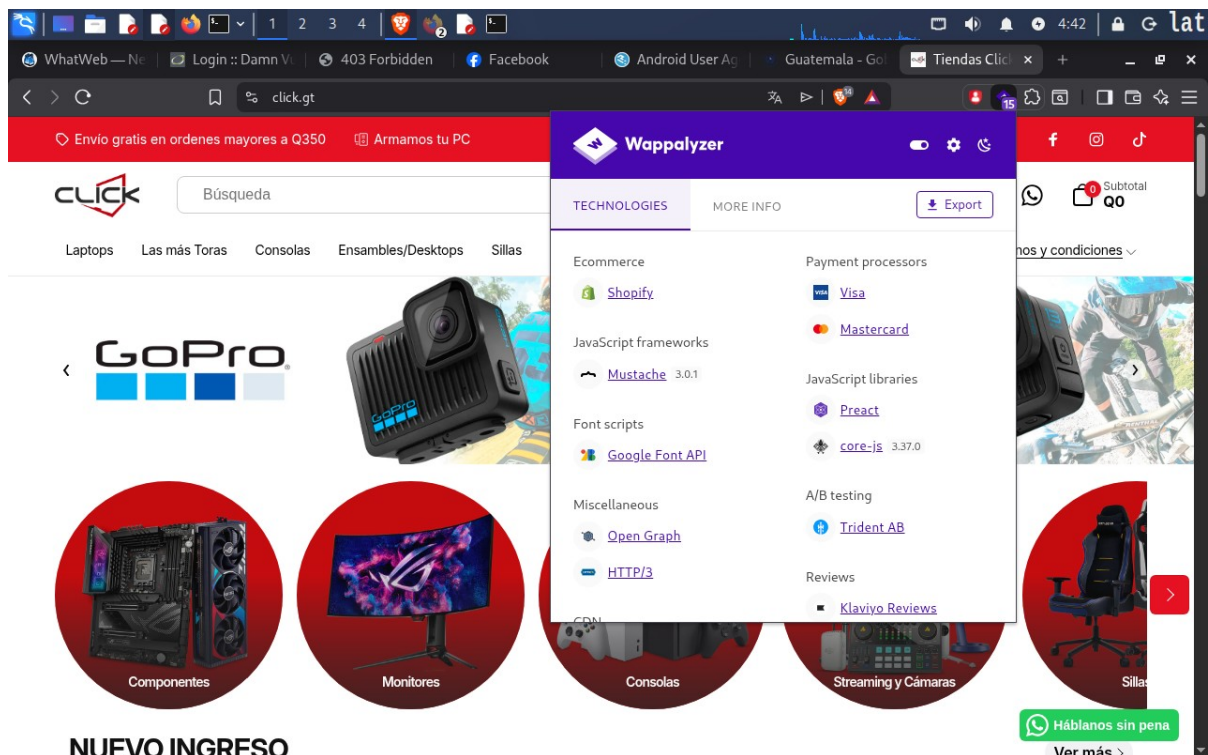


Figure 7 — Firefox on guatemala.gob.gt with Wappalyzer extension popup open. Technologies tab active. CMS: WordPress. CDN: Cloudflare. Widgets: Slider Revolution 6.5.16. Photo galleries: Slider Revolution 6.5.16. Page builder: wpBakery, Elementor 3.12.1. Analytics: Site Kit 1.158.0, Google Analytics GA4. SEO: All in One SEO Pack 4.6.1.1. Databases: MySQL. Partial "Blogs" category visible at bottom. Export button present. The site background shows a "ÚNETE A NUESTRO CANAL" campaign.

3.6 — Wappalyzer on click.gt (Shopify E-commerce)

Wappalyzer was then used on click.gt, a Guatemalan electronics e-commerce site, revealing its complete Shopify-based technology stack including payment processors, JavaScript frameworks, and analytics tools.



NUEVO INGRESO

Figure 8 — Firefox on click.gt (Tiendas Click Guatemala) with Wappalyzer popup. Technologies: Ecommerce: Shopify. Payment processors: Visa, Mastercard. JavaScript frameworks: Mustache 3.0.1. Font scripts: Google Font API. Miscellaneous: Open Graph, HTTP/3. JavaScript libraries: Preact, core-js 3.37.0. A/B testing: Trident AB. Reviews: Klaviyo Reviews. The site shows a GoPro camera product and computer hardware categories (Componentes, Monitores, Consolas, Streaming y Cámaras).

3.7 — WhatWeb Verbose Scan on click.gt

A verbose WhatWeb scan against click.gt revealed its full Shopify-based fingerprint including cookies, content language, email addresses, and Google Analytics configuration.

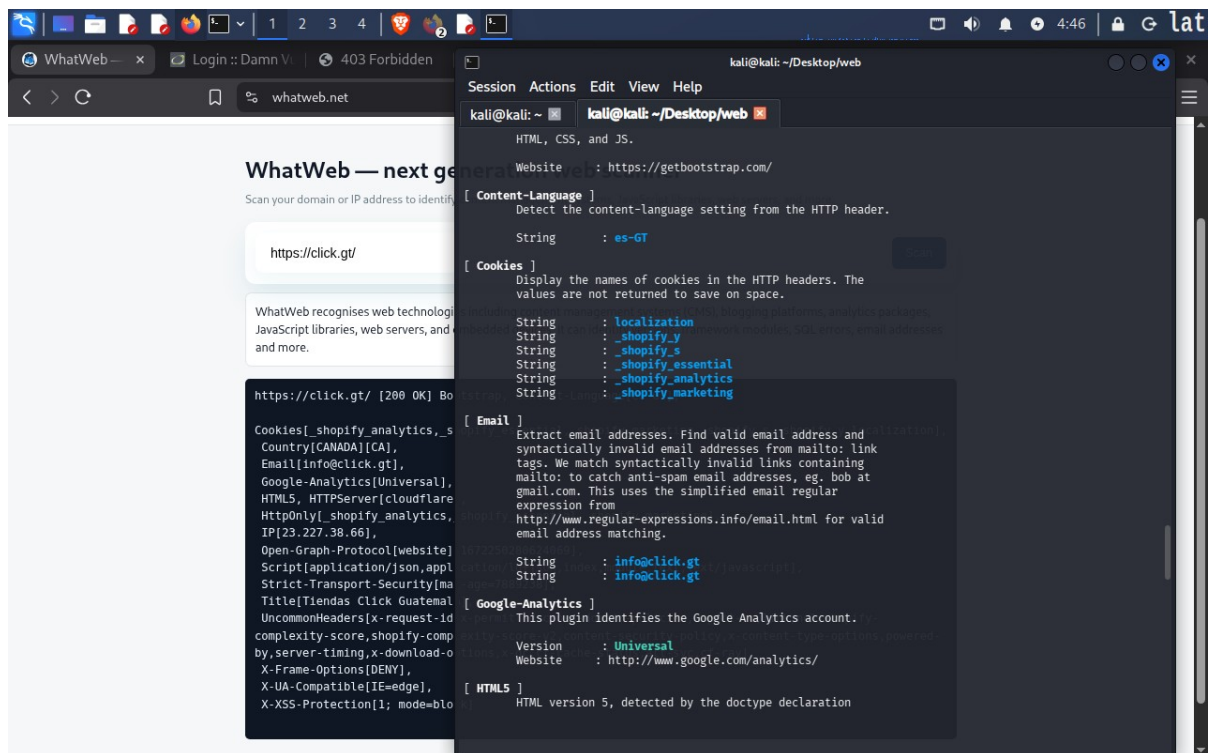


Figure 9 — Kali terminal: `whatweb https://click.gt/` returns [200 OK]. Detected plugins expanded (verbose): Bootstrap (HTML, CSS, JS, website getbootstrap.com). Content-Language: es-GT. Cookies: localization, _shopify_y, _shopify_s, _shopify_essential, _shopify_analytics, _shopify_marketing. Email plugin: info@click.gt (two instances). Google-Analytics: Version Universal, website google.com/analytics. HTML5 version 5.

4. Nikto — Web Server Vulnerability Scanner

4.1 — Nikto Scan Against Metasploitable2 Port 8081 (DVWA)

Nikto v2.6.0 was run against port 8081 (the DVWA Apache instance). The scanner identified multiple security issues: outdated Apache version (2.4.25, current is at least 2.4.66), missing security headers (HSTS, CSP, X-Content-Type-Options, Permissions-Policy, Referrer-Policy), insecure cookies (PHPSESSID without HttpOnly flag), directory indexing enabled on /config/ and /docs/, configuration files potentially accessible remotely, and the Apache default /icons/README file found. The admin login page /login.php was also confirmed.

```
kali@kali: ~  
kali@kali: ~/Desktop/web  
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the  
content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerabi  
lity-scanner/vulnerabilities/missing-content-type-header/  
+ 8218 requests: 0 errors and 7 items reported on the remote host  
+ End Time: 2026-06-02 04:50:18 (GMT-4) (15 seconds)  
  
+ 1 host(s) tested  
  
kali@kali: ~/Desktop/web  
$ nikto -h http://192.168.255.128:8081/  
- Nikto v2.6.0  
  
+ Target IP: 192.168.255.128  
+ Target Hostname: 192.168.255.128  
+ Target Port: 8081  
+ Platform: Linux/Unix  
+ Start Time: 2026-06-02 04:51:01 (GMT-4)  
  
+ Server: Apache/2.4.25 (Debian)  
+ ERROR: Failed to check for updates: 403  
+ [95] /: Cookie PHPSESSID created without the httponly flag. See: https://developer.mozilla.org/en-US/doc  
s/Web/HTTP/Cookies  
+ [95] /: Cookie security created without the httponly flag. See: https://developer.mozilla.org/en-US/doc  
s/Web/HTTP/Cookies  
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.  
+ [600050] Apache/2.4.25 appears to be outdated (current is at least 2.4.66).  
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla  
.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security  
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.o  
rg/en-US/docs/Web/HTTP/CSP  
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.or  
g/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options  
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en  
-US/docs/Web/HTTP/Headers/Permissions-Policy  
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US  
/docs/Web/HTTP/Headers/Referrer-Policy  
+ [750500] /config/: Directory indexing found.  
+ [000998] /config/: Configuration information may be available remotely.  
+ [750500] /docs/: Directory indexing found.  
+ [003584] /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-acce  
ss-to-iconsreadme/  
+ [006333] /login.php: Admin login page/section found.
```

Figure 10 — Kali terminal: `nikto -h http://192.168.255.128:8081/` — Nikto v2.6.0. Target IP: 192.168.255.128, Hostname: 192.168.255.128, Port: 8081, Platform: Linux/Unix, Start: 2026-06-02 04:51:01 (GMT-4). Results: Server Apache/2.4.25 (Debian). ERROR: Failed to check for updates: 403. + [95] Cookie PHPSESSID created without the httponly flag. + [95] Cookie security created without the httponly flag. + No CGI Directories found. + [600050] Apache/2.4.25 appears to be outdated (current at least 2.4.66). + [013587] Missing security headers: strict-transport-security, content-security-policy, x-content-type-options, permissions-policy, referrer-policy. + [007352] X-Content-Type-Options header not set. + 8218 requests, 0 errors, 7 items reported, 15 seconds. + [750500] /config/: Directory indexing found. + [000998] /config/: Configuration information may be available remotely. + [750500] /docs/: Directory indexing found. + [003584] /icons/README: Apache default file found. + [006333] /login.php: Admin login page/section found.